Data privacy & security choices

Project Udyam Digital · Airtel SYNC 2026, Enterprise Track A · Digital Personal Data Protection Act, 2023

Every choice below is implemented in the prototype, not aspirational. References point at the code that enforces it.

1 Data minimisation — ask for the least that works

The profile the advisor fills (`profile.py`) has **no field for PAN, Aadhaar, date of birth, personal address or bank details** — recommending a bundle needs none of them. Turnover is a band, never an exact figure, and the owner answers at most six questions. For verification, one 15-character GSTIN replaces about twenty form fields, because legal name, constitution, address and state come back from the registry. **Less typing and less data collected are the same change.**

2 Consent — specific, granular, provable, withdrawable

There is no single "I agree". Four purposes are presented separately (`consent.py`), each stating its data and retention:

PURPOSE	DATA	RETENTION	
Verify business identity	GST & Udyam numbers, business name/address, signatory	Images deleted at once; fields 8 yrs (licence rule)	Required
Set up and run the connection	Installation address, contact	Tenure + 8 yrs	Required
Order & service updates	Mobile number	Until switched off	Optional
Marketing	Mobile, email	Until switched off	Optional

- Optional purposes default to **off**; refusing them changes nothing about the service. Checkout is **blocked** until the two required consents are given — enforced server-side, not just in the UI.
- The **notice text actually shown** is stored with each consent and timestamped, so we can prove what was agreed to.
- The ledger is **append-only**: withdrawal adds a dated record and never deletes the original. Withdrawal is one tap on the tracker — **as easy to withdraw as it was to give** (s.6(4)).

3 Purpose limitation

The GST certificate is used for identity verification only, and is **never** fed to the recommendation engine — the rules engine receives only the structured profile. Registry services return a deliberately narrow projection of each record (`registry.py`): unneeded fields are dropped at the API boundary, not merely hidden in the UI.

4 Storage limitation

Uploaded documents are written to a temporary directory, read, and **deleted the moment extraction finishes** — the deletion is the code path, not a retention policy someone must remember to run (`main.py`). What survives is the handful of extracted fields needed to prove the business is real.

5 Masking and least exposure

Identifiers are masked wherever displayed or logged — `37TH******L1ZS`, `UDYAM-PB-00-***478` (`validators.py`). The KYC report never carries a raw GSTIN, and **an automated test asserts this across all twelve applicants**, so a future change cannot quietly reintroduce a leak.

> **An honest limitation.** To understand a free-text reply, the advisor sends that reply to Gemini; if the owner types their GSTIN into the chat, it travels with it. The prototype already detects GSTIN patterns locally (`llm.py`), so production would redact identifiers before the call, or run an India-hosted model. Documents and extracted KYC fields are **never** sent to the model — OCR and validation run entirely on our own infrastructure.

6 Security controls

- **In transit** TLS 1.3; **at rest** AES-256 for extracted identifiers. **Access** is role-based — partners see lead and status data, never identity documents — and every read of an identifier is audit-logged.
- **Integrity:** GSTIN checksums are verified locally before any lookup, so malformed or invented numbers never reach the registry API.
- **Fail closed:** an unverifiable document is referred for review, never approved on the benefit of the doubt. Blurred scans are refused *before* OCR, because OCR on a bad image produces confident nonsense.
- **No third-party sharing** — no data broker, no ad network, no cross-sale of customer lists.

7 Rights, and what production adds

The tracker exposes access, correction, withdrawal and erasure, plus a named grievance officer and the route to the Data Protection Board. **Beyond the prototype:** DigiLocker-issued documents (consent-based fetch is more minimal than upload), Aadhaar e-sign for the agreement, India-only data residency, a registered Consent Manager, and a 72-hour breach-notification runbook.